

Guía del estudiante

Módulo 3: Workload identities

Plan and implement workload identities. 20 a 25% del examen.

Modelo invertido: **esta guía se estudia antes de la sesión**. En vivo cazamos trampas y jugamos Kahoot con el porqué de cada distractor.

Sin dumps

Todo el contenido es original y está anclado a Microsoft Learn con links directos a los párrafos. Skills outline vigente: 27 de abril de 2026.

Contiene: mapa de skills con deep links · 12 trampas con frase clave · 3 visuales · 40 preguntas estilo examen con explicación por distractor · plan de la semana y ritual post-examen.

0. Cómo usar esta guía (20 minutos de lectura, 90 de práctica)

1. Lee el mapa

Sección 1. Un punto clave por skill del outline. Si algo no te suena, abre el deep link: cae justo en el párrafo que el examen pregunta.

2. Aprende las 12 trampas

Sección 2. Cada una trae la frase que la resume, la regla, y las palabras de la pregunta que la delatan.

3. Contesta el banco sin ver respuestas

Sección 4. Anota tus respuestas. Luego revisa la sección 5 y lee el "por qué las otras no": ahí está el valor.

Las preguntas que resuelven casi todo M3: Objeto, identidad, consentimiento y control. Cuando no sepas la respuesta, pregúntate:

1. **Objeto:** ¿es el application object (app registration) o el service principal (enterprise app)? Cada uno guarda cosas distintas.
2. **Identidad:** ¿managed identity, service principal o cuenta? System-assigned muere con el recurso; user-assigned se comparte; fuera de Azure la managed identity no llega sin Arc.
3. **Consentimiento:** ¿delegated o application? ¿user consent o admin consent? Quién puede consentir decide la respuesta.
4. **Control:** ¿lo hace Entra (assignment, roles, App Proxy) o Defender for Cloud Apps (discovery, session policies)?

Con eso eliminas dos distractores en la mayoría de las preguntas del módulo.

Datos duros del examen. 700 de 1000 para pasar (escala ajustada, no 70% de aciertos). Practice assessment oficial gratis: learn.microsoft.com/credentials/certifications/exams/sc-300/practice/assessment. Exam sandbox: aka.ms/examdemo. Study guide oficial: learn.microsoft.com/credentials/certifications/resources/study-guides/sc-300.

1. Mapa del módulo: skills, punto clave y deep links

Cada fila corresponde a un bullet del skills outline oficial. El punto clave es lo que el examen realmente mide; los deep links caen en el párrafo exacto de Learn.

Subdominio 1: Identities for applications and Azure workloads

Módulos oficiales en Learn: [implement-access-management-for-azure-resources](https://learn.microsoft.com/credentials/certifications/exams/sc-300/practice/assessment) · [implement-managed-identities](https://learn.microsoft.com/credentials/certifications/exams/sc-300/practice/assessment)

Skill **Select appropriate identities for applications and Azure workloads (managed identities, service principals, user accounts, managed service accounts)**

Workload en Azure: **managed identity**. Workload fuera de Azure sin Arc: **service principal** con certificado o federated credential. Servicio Windows on-premises: **gMSA** (varios servers o load balancer) o **sMSA** (un server). User account como service account: no recomendado.

Link principal: [entra/architecture/govern-service-accounts](#)

- [overview](#) #differences-between-system-assigned-and-user-assigned-managed-identities
- [service-accounts-on-premises](#) #choose-the-right-type-of-service-account
- [app-objects-and-service-principals](#) #service-principal-object

Skill **Create managed identities**

System-assigned se activa en el recurso y muere con él. User-assigned es un recurso aparte, se comparte entre recursos y hay que borrarlo a mano. Crear un user-assigned pide el rol de Azure **Managed Identity Contributor**.

Link principal: [entra/identity/managed-identities-azure-resources/how-manage-user-assigned-managed-identities](#)

- [overview](#) #managed-identity-types
- [manage-user-assigned-managed-identities-azure-cli](#) #create-a-user-assigned-managed-identity

Skill **Assign a managed identity to an Azure resource**

Asignar un user-assigned a una VM pide **Virtual Machine Contributor + Managed Identity Operator** (roles de Azure RBAC). No hace falta ningún rol de Microsoft Entra.

Link principal: [entra/identity/managed-identities-azure-resources/how-to-configure-managed-identities](#)

- [how-to-configure-managed-identities](#) #user-assigned-managed-identity
- [how-to-configure-managed-identities?pivots=qs-configure-portal-windows-vm](#) #enable-system-assigned-managed-identity-on-an-existing-vm

Skill **Use a managed identity assigned to an Azure resource to access other Azure resources**

Tres pasos: crear o asignar la identidad, **autorizarla en el recurso destino** (por ejemplo Storage Blob Data Reader) y pedir el token con Azure.Identity o MSAL. La managed identity no tiene application object: los permisos de Graph se asignan directo a su service principal. Fuera de Azure solo con **Azure Arc** (system-assigned).

Link principal: [entra/identity/managed-identities-azure-resources/overview](#)

- [overview](#) #use-managed-identity-directly
- [managed-identities-faq](#) #do-managed-identities-have-a-backing-app-object
- [managed-identity-authentication](#)

Subdominio 2: Plan, implement, and monitor the integration of enterprise applications

Módulos oficiales en Learn: [plan-design-integration-of-enterprise-apps-for-ss](#) · [implement-monitor-integration-of-enterprise-apps-for-ss](#)

Skill Configure and manage application-level and tenant-level settings

Nivel app: **Enabled for users to sign in** (No = no hay tokens para nadie), **Assignment required** (solo asignados obtienen token) y **Visible to users** (solo esconde en My Apps). Nivel tenant: Users can register applications, user consent settings y admin consent workflow.

Link principal: [entra/identity/enterprise-apps/application-properties](#)

- [application-properties](#) #enabled-for-users-to-sign-in
- [application-properties](#) #assignment-required
- [delegate-app-roles](#) #restrict-who-can-create-applications

Skill Assign appropriate Microsoft Entra roles to users to manage enterprise applications

Application Administrator = todo en apps más Application Proxy. **Cloud Application Administrator** = lo mismo sin **Application Proxy**. Ninguno administra Conditional Access ni consiente application permissions de Microsoft Graph (eso es Privileged Role Administrator).

Link principal: [entra/identity/role-based-access-control/delegate-app-roles](#)

- [delegate-app-roles](#) #assign-built-in-application-administrator-roles
- [permissions-reference](#) #cloud-application-administrator
- [delegate-by-task](#) #application-proxy-least-privileged-roles

Skill Design and implement integration for on-premises apps by using Microsoft Entra Application Proxy

Pre-auth **Microsoft Entra ID** (default) da CA, MFA, SSO y monitoreo con Defender; **Passthrough** no. Connectors solo salen por 80 y 443, mínimo dos por connector group. SSO a apps IWA = **KCD** desde el computer account del connector al SPN. Custom domain = PFX con private key + CNAME a msapproxy.net. Licencia P1 o P2.

Link principal: [entra/identity/app-proxy/overview-what-is-app-proxy](#)

- [application-proxy-add-on-premises-application](#) #add-an-on-premises-app-to-microsoft-entra-id
- [how-to-configure-sso-with-kcd](#) #configure-single-sign-on
- [how-to-configure-custom-domain](#) #certificates-for-custom-domains

Skill Design and implement integration for SaaS apps

SAML: **Identifier (Entity ID)** y **Reply URL (ACS)** son obligatorios; Sign on URL solo para SP-initiated. El certificado de firma dura 3 años por default, avisa a 60, 30 y 7 días (hasta 5 correos), y no se edita: se crea uno nuevo, se sube a la app y se activa.

Link principal: [entra/identity/enterprise-apps/add-application-portal-setup-sso](#)

- [add-application-portal-setup-sso](#) #configure-single-sign-on-in-the-tenant
- [tutorial-manage-certificates-for-federated-single-sign-on](#) #renew-a-certificate-that-is-set-to-expire-soon
- [tutorial-manage-certificates-for-federated-single-sign-on](#) #add-email-notification-addresses-for-certificate-expiraton

Skill Assign, classify, and manage users, groups, and app roles for enterprise applications

Asignar grupos pide **P1 o P2** y **no soporta grupos anidados**. Si la app expone app roles, eliges el rol al asignar. "Classify" = clasificar permisos delegados como low impact para el user consent.

Link principal: [entra/identity/enterprise-apps/assign-user-or-group-access-portal](#)

- [assign-user-or-group-access-portal](#) #prerequisites
- [configure-permission-classifications](#)
- [howto-add-app-roles-in-apps](#) #assign-users-and-groups-to-microsoft-entra-roles

Skill Configure and manage user and admin consent

User consent: no permitir, verified publishers con permisos low impact, permitir todo, o Microsoft managed. Si el usuario no puede consentir, el **admin consent workflow** manda la solicitud a reviewers (ser reviewer no da permisos; los reviewers nuevos no ven solicitudes viejas; hay días de expiración). Apps con Assignment required siempre piden admin consent.

Link principal: [entra/identity/enterprise-apps/user-admin-consent-overview](#)

- [configure-user-consent](#) #configure-user-consent-settings
- [configure-admin-consent-workflow](#) #enable-the-admin-consent-workflow
- [grant-admin-consent](#) #prerequisites

Skill Create and manage application collections

Collections agrupan apps en una pestaña de My Apps. Piden **P1 o P2**, se crean en Enterprise apps > App launchers, y solo filtran apps que el usuario ya tiene asignadas.

Link principal: [entra/identity/enterprise-apps/access-panel-collections](#)

- [access-panel-collections](#) #create-a-collection
- [myapps-overview](#) #create-collections

Subdominio 3: Plan and implement app registrations

Módulos oficiales en Learn: [implement-app-registration](#) · [register-apps-use-microsoft-entra-id](#)

Skill Plan for app registrations

App registration = **application object** (uno, en el home tenant). Enterprise app = **service principal** (uno por tenant que usa la app). Single tenant tiene un solo SP; multitenant crea un SP en cada tenant que consiente. Borrar el app object borra el SP del home tenant.

Link principal: [entra/identity-platform/app-objects-and-service-principals](#)

- [app-objects-and-service-principals](#) #relationship-between-application-objects-and-service-principals
- [app-objects-and-service-principals](#) #consequences-of-modifying-and-deleting-applications
- [single-and-multi-tenant-apps](#) #who-can-sign-in-to-your-app

Skill Create app registrations

Por default cualquier usuario registra apps. Si pones **Users can register applications = No**, el rol de menor privilegio para registrar es **Application Developer** (queda como owner de lo que crea).

Link principal: [entra/identity-platform/quickstart-register-app](#)

- [delegate-app-roles](#) #restrict-who-can-create-applications
- [app-objects-and-service-principals](#) #application-registration

Skill Configure app authentication

Redirect URI por plataforma: Web, **Single-page application**, iOS/macOS, Android, Mobile and desktop. Daemon no necesita redirect URI. Credenciales: **certificate** mejor que secret (secret máximo 24 meses), **federated credential** para GitHub Actions, Kubernetes u otro issuer.

Link principal: [entra/identity-platform/how-to-add-redirect-uri](#)

- [how-to-add-redirect-uri](#) #add-a-redirect-uri
- [how-to-add-credentials](#) #add-a-credential-to-your-application
- [msal-client-application-configuration](#) #redirect-uri

Skill Configure API permissions

Delegated (scopes, con usuario, consienten usuarios o admin) contra **Application** (app roles, sin usuario, solo admin). Para exponer tu API: App ID URI `api://<client-id>` y scopes con "Who can consent" (Admins and users o Admins only).

Link principal: [entra/identity-platform/permissions-consent-overview](#)

- [permissions-consent-overview](#) #types-of-permissions
- [quickstart-configure-app-expose-web-apis](#) #add-a-scope
- [grant-admin-consent](#) #grant-admin-consent-in-app-registrations-pane

Skill Create app roles

App role: Display name, **Allowed member types** (Users/Groups, Applications o ambos), Value (sin espacios) que sale en el claim **roles**. Con Applications, el rol aparece como application permission en My APIs. Groups claim tiene límite de 200 (JWT) y 150 (SAML).

Link principal: [entra/identity-platform/howto-add-app-roles-in-apps](#)

- [howto-add-app-roles-in-apps](#) #declare-roles-for-an-application
- [optional-claims](#) #configure-groups-optional-claims
- [custom-rbac-for-developers](#) #rbac-options

Subdominio 4: Manage and monitor app access by using Microsoft Defender for Cloud Apps

Módulos oficiales en Learn: [implement-cloud-app-security-cloud-discovery](#)

Skill Analyze Cloud Discovery results by using Defender for Cloud Apps

Snapshot = subes logs a mano, una vez. **Continuous** = Defender for Endpoint, log collector (Syslog o FTP), Secure Web Gateway o API. Marcar **Unsanctioned** no bloquea solo: bloquea si hay integración (MDE o SWG) o si exportas un block script.

Link principal: [defender-cloud-apps/set-up-cloud-discovery](#)

- [set-up-cloud-discovery](#) #snapshot-and-continuous-risk-assessment-reports
- [governance-discovery](#) #sanctioningunsanctioning-an-app
- [mde-govern](#) #enable-cloud-app-blocking-with-defender-for-endpoint

Skill Configure connected apps

App connector = API del proveedor: cuentas, audit trail, governance de cuentas, permisos de apps y scan de datos (cada 12 horas y casi en tiempo real). No es proxy y no controla la sesión en vivo.

Link principal: [defender-cloud-apps/enable-instant-visibility-protection-and-governance-actions-for-your-apps](#)

- [enable-instant-visibility-protection-and-governance-actions-for-your-apps](#) #how-app-connectors-scan-and-collect-data
- [protect-office-365](#) #connect-microsoft-365-to-microsoft-defender-for-cloud-apps

Skill Implement application-enforced restrictions

Session control de CA **Use app enforced restrictions**: solo **Exchange Online y SharePoint Online**.

Entra pasa info del device y la app da experiencia completa o limitada (web-only). No necesita Defender for Cloud Apps.

Link principal: [entra/identity/conditional-access/concept-conditional-access-session#application-enforced-restrictions](#)

- [policy-all-users-app-enforced-restrictions](#) #overview
- [control-access-from-unmanaged-devices](#) #how-do-i-limit-access

Skill Configure Conditional Access app control

Primero una política de CA con **Session > Use Conditional Access App Control** (Monitor only, Block downloads o Use custom policy). Las apps de Entra se onboardean solas; las de otro IdP, a mano. Pide Entra ID P1 y licencia de Defender for Cloud Apps.

Link principal: [defender-cloud-apps/proxy-intro-aad](#)

- [proxy-intro-aad](#) #activities-in-conditional-access-app-control
- [concept-conditional-access-session](#) #conditional-access-application-control
- [conditional-access-app-control-how-to-overview](#) #prerequisites

Skill Create access and session policies in Defender for Cloud Apps

Access policy = dejar entrar o bloquear (browser, o mobile and desktop si pones el filtro Client app).

Session policy = controlar lo que pasa dentro de la sesión en el browser (download, copy, print, upload, label). Entre session policies gana la más restrictiva.

Link principal: [defender-cloud-apps/session-policy-aad](#)

- [session-policy-aad](#) #prerequisites
- [session-policy-aad](#) #access-controls-in-session-policies
- [access-policy-aad](#) #create-a-defender-for-cloud-apps-access-policy

Skill Implement and manage policies for OAuth apps

OAuth app policy filtra por **Permission level** (High, Medium, Low), **Community use** (Common, Uncommon, Rare) y cuántos usuarios autorizaron. Acción en Microsoft 365: **Revoke app**. Pide el app connector de Microsoft 365, Google Workspace o Salesforce.

Link principal: [defender-cloud-apps/app-permission-policy](#)

- [app-permission-policy](#) #create-a-new-oauth-app-policy
- [policies-cloud-discovery](#) #detect-risky-oauth-apps
- [manage-app-permissions](#) #working-with-the-oauth-apps-page

Skill Manage the Cloud app catalog

Más de 31,000 apps con más de 90 factores de riesgo en 4 categorías: General, Security, Compliance y Legal. **Score metrics** cambia pesos para todo el tenant; **Override app score** cambia una sola app; **Request score update** le pide a Microsoft revisar.

Link principal: [defender-cloud-apps/risk-score](#)

- [risk-score](#) #risk-scoring-process
- [risk-score](#) #customize-the-risk-score
- [risk-score](#) #override-the-risk-score

2. Las 12 trampas de M3

Memoriza la frase, entiende la regla, reconoce las palabras que delatan. Los números son para consultar, no para memorizar.

1 App registration contra enterprise application

"App registration es el molde, enterprise app es la galleta: un molde en casa, una galleta por tenant."

- App registration = **application object**, uno solo, en el home tenant. Enterprise app = **service principal**, uno por cada tenant que usa la app (multitenant crea uno en cada tenant que consiente).
- Cambios al application object se reflejan en el SP del home tenant. Una managed identity tiene **solo service principal**, sin application object: sus permisos de Graph van directo al SP.

Palabras que delatan: "home tenant", "multitenant", "partner tenant grants consent", "which object is created", "Managed application in local directory", "App registrations vs Enterprise applications".

Learn: [app-objects-and-service-principals](#) #relationship-between-application-objects-and-service-principals · Practica con Q7, Q8, Q22

2 System-assigned contra user-assigned

"System-assigned vive y muere con su recurso; user-assigned es roomie: la compartes y la borras tú."

- System-assigned: una identidad, un recurso, se borra con él. User-assigned: recurso aparte, se asigna a muchos, se puede **pre-autorizar** antes de crear las VMs, y es la recomendada para servicios de Microsoft.
- Crear user-assigned: **Managed Identity Contributor**. Asignarla a una VM: **Virtual Machine Contributor + Managed Identity Operator**. Son roles de Azure RBAC, no de Entra. Después se autoriza en el destino (por ejemplo Storage Blob Data Reader).

Palabras que delatan: "same identity for all instances", "recreated frequently", "before the VMs are deployed", "shared across", "least privilege to assign", "when the VM is deleted".

Learn: [overview](#) #differences-between-system-assigned-and-user-assigned-managed-identities · Practica con Q1, Q2, Q4, Q5

3 Workload fuera de Azure: la managed identity no llega

"Managed identity no sale de Azure (salvo con Arc). Afuera: service principal con cert o federated. On-prem Windows: gMSA."

- Server on-premises solo tiene managed identity si es **Azure Arc-enabled** (system-assigned). Sin Arc: service principal con **certificate** (mejor que secret; el secret dura máximo 24 meses) o **federated credential** si hay un IdP externo (GitHub Actions, Kubernetes).
- Servicio Windows on-premises: **gMSA** para varios servers o load balancer, **sMSA** para uno solo. User account como service account es la última opción.

Palabras que delatan: "on-premises datacenter", "not onboarded to Azure Arc", "GitHub Actions", "no secrets stored", "more secure than a client secret", "behind a load balancer", "password rotated automatically".

Learn: [service-accounts-on-premises](#) #choose-the-right-type-of-service-account · Practica con Q3, Q6, Q24

4 Delegated contra application, y quién consiente

"Delegated = actúo como tú; application = actúo como yo. Y 'como yo' siempre lo aprueba un admin."

- Delegated (scopes) = hay usuario y la app no ve más que él; consienten usuarios o admin. Application (app roles) = sin usuario, ve todo lo del permiso; **solo admin**.
- Application permissions de **Microsoft Graph** las consiente **Privileged Role Administrator** (o Global Admin). Application Admin y Cloud Application Admin consienten todo lo demás. Un scope marcado "Admins only" también pide admin.

Palabras que delatan: "without a signed-in user", "daemon", "background service", "on behalf of the signed-in user", "Microsoft Graph application permission", "Grant admin consent is unavailable", "Admins only".

Learn: [permissions-consent-overview](#) #types-of-permissions · Practica con Q7, Q18, Q27, Q30

5 User consent, step-up y admin consent workflow

"Si el usuario no puede consentir, el workflow le da un botón para pedir; ser reviewer no te da superpoderes."

- User consent: no permitir, **verified publishers con permisos low impact**, permitir todo, o dejar que Microsoft lo maneje (default en tenants nuevos). Risk-based step-up consent viene activo y solo actúa si hay user consent. Apps con Assignment required siempre piden admin consent.
- Admin consent workflow: reviewers por usuario, grupo o rol; para **aprobar** necesitan el rol adecuado; los reviewers nuevos no ven solicitudes viejas; las solicitudes expiran en los días que configuras.

Palabras que delatan: "request approval from the consent prompt", "unverified publisher", "reviewers", "expires after", "added later as a reviewer", "risky consent request", "AADSTS90094".

Learn: [configure-admin-consent-workflow](#) #enable-the-admin-consent-workflow · Practica con Q16, Q17

6 Application Admin contra Cloud Application Admin

"Cloud App Admin es App Admin sin el Proxy. Y ninguno de los dos toca CA ni Graph application permissions."

- **Application Administrator:** todo en enterprise apps y app registrations, más **Application Proxy** (apps y connector groups). **Cloud Application Administrator:** igual, sin App Proxy.
- Si "Users can register applications" está en No, el rol mínimo para registrar es **Application Developer**. Ninguno de estos roles administra Conditional Access.

Palabras que delatan: "connector group", "publish on-premises apps", "least privilege", "users can't register applications", "configure SAML SSO", "create a Conditional Access policy for the app".

Learn: [delegate-app-roles](#) #assign-built-in-application-administrator-roles · Practica con Q9, Q18, Q21

7 Application Proxy: pre-auth, connectors, custom domain y KCD

"Sin pre-auth de Entra no hay CA, ni MFA, ni SSO. El connector solo sale, nunca entra."

- Pre-auth **Microsoft Entra ID** (default) da CA, MFA, SSO y monitoreo con Defender; **Passthrough** no. Connectors solo outbound (80 y 443), mínimo **dos por connector group**. Custom domain = **PFX con private key + CNAME** a msapproxy.net. Licencia P1 o P2.
- SSO a apps IWA = **KCD**: en AD, el computer account del connector delega al SPN de la app ("specified services only" + "any authentication protocol"); en Entra, SSO Integrated Windows authentication con el SPN. Dominios distintos: resource-based KCD.

Palabras que delatan: "Integrated Windows Authentication", "Kerberos", "SPN", "Passthrough", "no inbound ports", "custom domain", "expenses.contoso.com", "high availability", "different domains".

Learn: [how-to-configure-ssso-with-kcd](#) #configure-single-sign-on · Practica con Q10, Q11, Q12

8 SAML: los campos y el rollover del certificado

"Entity ID dice quién eres, Reply URL dice a dónde mando el token. El cert no se edita: se crea otro."

- **Identifier (Entity ID)** y **Reply URL (ACS)** son obligatorios; **Sign on URL** solo para SP-initiated. El Login URL y el Microsoft Entra Identifier de "Set up" van del lado del vendor.
- Certificado autogenerado: **3 años**, avisos a 60, 30 y 7 días (hasta 5 correos). Renovar sin downtime: nuevo cert con fecha traslapada, descargar, subir a la app, **Make certificate active**, probar.

Palabras que delatan: "Assertion Consumer Service", "Entity ID", "SP-initiated", "certificate expires in", "no downtime", "notification email", "change the expiration date".

Learn: [tutorial-manage-certificates-for-federated-single-sign-on](#) #renew-a-certificate-that-is-set-to-expire-soon · Practica con Q13, Q15

9 Visible, Assignment required, Enabled, grupos y collections

"Visible esconde, Assignment required filtra, Enabled apaga. Y los grupos anidados no cuentan."

- **Visible to users** solo esconde en My Apps. **Assignment required** = solo asignados obtienen token. **Enabled for users to sign in = No** = no hay tokens para nadie, sin perder la configuración. Estos son settings de app; Users can register applications y consent son de tenant.
- Asignar grupos pide **P1 o P2** y **no cascada a grupos anidados**. **Collections** (App launchers, P1 o P2) agrupan apps en una pestaña de My Apps, pero solo muestran apps ya asignadas.

Palabras que delatan: "nested group", "not assigned to the app", "separate tab in My Apps", "hide the app", "stop all sign-ins without deleting", "only members of".

Learn: [application-properties](#) #assignment-required · Practica con Q14, Q19, Q20

10 Configurar la app: plataforma, scope, app role o groups claim

"Scope para 'on behalf of', app role para 'sin usuario' o para roles de usuario; el groups claim topa en 200."

- Redirect por **plataforma**: Single-page application para JavaScript con PKCE, Web para apps de servidor, daemon sin redirect. "On behalf of user" = **scope** en Expose an API (App ID URI primero); "sin usuario" = **app role** con Allowed member types Applications.
- Autorizar usuarios dentro de la app: app role **Users/Groups** (claim roles). Groups claim: límite **200 en JWT y 150 en SAML**; usa **Groups assigned to the application**. App role dado a un grupo con un service principal no emite roles.

Palabras que delatan: "React", "MSAL.js", "PKCE", "Expose an API", "roles claim", "group overage", "more than 200 groups", "Allowed member types".

Learn: [howto-add-app-roles-in-apps](#) #declare-roles-for-an-application · Practica con Q23, Q25, Q26, Q28, Q29

11 Cloud Discovery, catalog y el mito del Unsanctioned

"Unsanctioned es una etiqueta, no un firewall: el bloqueo lo hace MDE o tu appliance."

- **Snapshot** = subes logs a mano, una vez. **Continuous** = Defender for Endpoint (también fuera de la oficina), log collector (Syslog o FTP), SWG o API. Bloqueo con MDE: Cloud y Network Protection, Enforce app access, Custom network indicators y luego Unsanctioned (hasta 3 horas; scoped profiles por device group).
- Catalog: más de 31,000 apps, 4 categorías (General, Security, Compliance, Legal). **Score metrics** cambia pesos para todas las apps; **Override** cambia una; **Request score update** le pide a Microsoft.

Palabras que delatan: "one-time assessment", "exported logs", "users working from home", "continuous", "block on devices", "specific device groups", "weight", "all apps", "only this app".

Learn: [set-up-cloud-discovery](#) #snapshot-and-continuous-risk-assessment-reports · Practica con Q31, Q32, Q33, Q34, Q39

12 Session control: quién hace qué

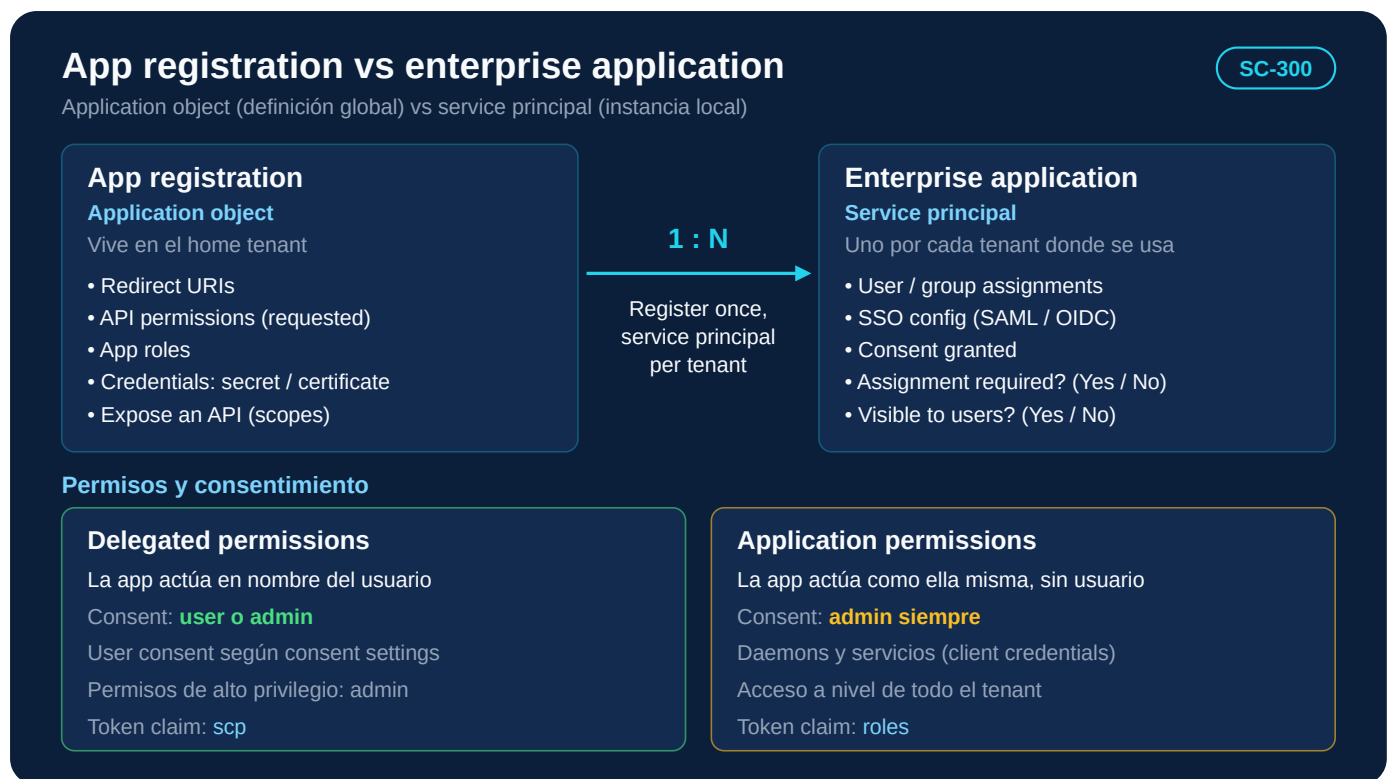
"Session policy sin el CA 'Use Conditional Access App Control' es perro sin dientes. Y app enforced solo muerde en Exchange y SharePoint."

- Access y session policies necesitan una política de CA con **Session > Use Conditional Access App Control**. **Access policy** = entrar o no (con Client app = Mobile and desktop bloquea clientes nativos). **Session policy** = qué haces dentro, solo browser. **Use app enforced restrictions** = solo EXO y SPO, sin licencia de Defender for Cloud Apps.
- **App connector** = API (actividad, cuentas, archivos), sin proxy. **OAuth app policy** = Permission level, Community use y usuarios que autorizaron; acción Revoke app; pide el connector.

Palabras que delatan: "session policy has no effect", "desktop sync client", "native client", "browser only", "limited web-only access", "no Defender for Cloud Apps licenses", "through the vendor's API", "without a proxy", "rare community use", "high permission level".

Learn: [session-policy-aad](#) #prerequisites · Practica con Q35, Q36, Q37, Q38, Q40

3. Visuales para no olvidar



App registration vs enterprise application. El application object vive en el home tenant; el service principal existe en cada tenant donde se usa la app. Delegated permissions las consiente el usuario; application permissions solo un admin.

4. Banco de preguntas: 40 preguntas estilo examen

En inglés, como el examen. Contesta sin ver la sección 5. En las series Yes/No cada afirmación se evalúa sola; en drag/order solo cuentan las acciones que sí van, en orden. Los case studies aplican a las dos preguntas que los siguen.

Subdominio 1: Identities for applications and Azure workloads

Q1 **Multiple choice** Select appropriate identities for applications and Azure workloads

Contoso runs an order-processing workload on a virtual machine scale set. Instances are deleted and re-created several times a day. The security team must grant the workload access to an Azure Key Vault **before** the new instances are deployed, and every instance must use **the same identity**. Developers must not manage any credentials.

Which identity should you use?

- A. A system-assigned managed identity enabled on each instance
- B. A user-assigned managed identity assigned to the scale set
- C. An app registration with a client secret stored in the application settings
- D. A synchronized Active Directory user account used as a service account

Q2 Yes/No series Create managed identities

Fabrikam has the following resources:

- VM1, an Azure virtual machine with a system-assigned managed identity enabled.
- UAMI1, a user-assigned managed identity assigned to both VM1 and App1 (an Azure App Service web app).

For each of the following statements, select Yes or No.

1. If VM1 is deleted, the service principal for VM1's system-assigned managed identity is deleted automatically.
2. If VM1 is deleted, UAMI1 is also deleted.
3. You can assign VM1's system-assigned managed identity to App1 so both resources share it.

Q3 Multiple choice Select appropriate identities for applications and Azure workloads

Adatum runs a reporting application on three Windows servers in its on-premises datacenter. The application must read secrets from Azure Key Vault. Company policy forbids onboarding the servers to Azure Arc. The security team requires a credential that is more secure than a password-like string.

What should you use for the application?

- A. A system-assigned managed identity for each server
- B. A user-assigned managed identity shared by the three servers
- C. An app registration (service principal) that authenticates with a certificate
- D. An app registration (service principal) that authenticates with a client secret

Q4 Select two Assign a managed identity to an Azure resource

You created a user-assigned managed identity named UAMI-Orders. An operator must assign UAMI-Orders to an existing Azure virtual machine named VM-Orders. You must follow the principle of least privilege.

Which **two** roles should the operator have? Each correct answer presents part of the solution.

- A. Managed Identity Contributor
- B. Managed Identity Operator
- C. Virtual Machine Contributor
- D. Application Administrator (Microsoft Entra role)
- E. Owner on the subscription

Q5 **Drag/order** Use a managed identity to access other Azure resources

A web app hosted in Azure App Service must read blobs from a storage account named stfinance. No secrets can be stored in the app. You decide to use a user-assigned managed identity named UAMI-Web.

Which **four** actions should you perform, **in sequence**?

- A. Create the user-assigned managed identity UAMI-Web.
- B. Add UAMI-Web to the App Service under Identity > User assigned.
- C. Assign the Storage Blob Data Reader role to UAMI-Web on stfinance.
- D. In the app code, request a token with Azure.Identity (ManagedIdentityCredential) by using the client ID of UAMI-Web.
- E. Create a client secret for UAMI-Web in App registrations.
- F. Grant admin consent for UAMI-Web in Enterprise applications.

Q6 **Multiple choice** Select appropriate identities for applications and Azure workloads

Litware runs a Windows service on three on-premises servers behind a network load balancer. All servers run Windows Server 2022 and are joined to the same Active Directory domain. The service needs a domain identity whose password is rotated automatically. There's no Azure dependency.

Which account type should you use?

- A. A standalone managed service account (sMSA)
- B. A group managed service account (gMSA)
- C. A system-assigned managed identity
- D. A domain user account with Password never expires set

Q7 **Multiple choice** Use a managed identity to access other Azure resources

An Azure Functions app named FuncHR uses a system-assigned managed identity. FuncHR must call Microsoft Graph to read all user profiles without a signed-in user (application permission User.Read.All).

How should you grant the permission?

- A. In App registrations, open FuncHR, add the User.Read.All application permission, and select Grant admin consent.
- B. Use Microsoft Graph PowerShell to create an app role assignment of User.Read.All from the Microsoft Graph service principal to FuncHR's managed identity service principal.
- C. Assign the Reader Azure role to FuncHR's managed identity at the subscription scope.
- D. In Enterprise applications, open FuncHR and add User.Read.All from the Permissions page.

Q8 **Yes/No series** Select appropriate identities for applications and Azure workloads

You review the service principals in the Contoso tenant.

For each of the following statements, select Yes or No.

1. When you register an application in the Microsoft Entra admin center, an application object and a service principal are created in the home tenant.
2. A service principal that represents a managed identity has an associated application object that you can manage in App registrations.
3. A legacy service principal can be used in any tenant that consents to it.

Subdominio 2: Enterprise applications

Q9 **Multiple choice** Assign appropriate Microsoft Entra roles to manage enterprise applications

An administrator named Marta must publish on-premises web apps by using Microsoft Entra Application Proxy, create connector groups, and configure SAML single sign-on for gallery apps. You must follow the principle of least privilege.

Which role should you assign to Marta?

- A. Cloud Application Administrator
- B. Application Administrator
- C. Application Developer
- D. Global Administrator

Q10 **Yes/No series** Design and implement integration for on-premises apps by using Application Proxy

Contoso publishes an internal web app named App1 by using Microsoft Entra Application Proxy with these settings:

- Pre Authentication: **Passthrough**
- Connector group: CG-Madrid, which contains **one** private network connector
- A Conditional Access policy targets App1 and requires multifactor authentication.

For each of the following statements, select Yes or No.

1. Users who open App1's external URL are prompted for MFA by the Conditional Access policy.
2. The perimeter firewall must allow inbound TCP 443 from the internet to the connector server.
3. To follow Learn guidance for high availability, CG-Madrid should have at least two connectors.

Q11 **Drag/order** Design and implement integration for on-premises apps by using Application Proxy

Contoso has an on-premises intranet app that uses Integrated Windows Authentication (IWA). Remote users must reach it through Microsoft Entra Application Proxy and get single sign-on after they sign in to Microsoft Entra ID. The connector server and the app server are in the same domain.

Which **four** actions should you perform, **in sequence**?

- A. Install and register a private network connector on a domain-joined Windows Server.
- B. In Active Directory Users and Computers, on the connector server's computer account, select Trust this computer for delegation to specified services only, select Use any authentication protocol, and add the app's SPN.
- C. Publish the app in Application Proxy with Pre Authentication set to Microsoft Entra ID.
- D. On the app's Single sign-on page, select Integrated Windows authentication, enter the Internal Application SPN, and choose the Delegated Login Identity.
- E. Change Pre Authentication to Passthrough.
- F. Configure SAML-based single sign-on and use the app's SPN as the Identifier (Entity ID).

Q12 **Multiple choice** Design and implement integration for on-premises apps by using Application Proxy

You publish an app through Application Proxy. Users must reach it at `https://expenses.contoso.com`. The domain contoso.com is already verified in Microsoft Entra ID.

What else must you do?

- A. Upload a PFX certificate that includes the private key for expenses.contoso.com, and create a CNAME record that points expenses.contoso.com to the msapproxy.net address shown on the Application proxy page.
- B. Upload a .cer certificate for expenses.contoso.com, and create an A record that points to the public IP address of the connector server.
- C. Create a TXT record for expenses.contoso.com. No certificate is required because Microsoft provides one.
- D. Install the certificate on the connector server and open inbound TCP 443 to it.

Q13 **Multiple choice** Design and implement integration for SaaS apps

You add the non-gallery SaaS app Litware Portal to Microsoft Entra ID and select SAML single sign-on. The vendor sends these values:

- SP Entity ID: `https://portal.litware.com/sp`
- Assertion Consumer Service URL: `https://portal.litware.com/sso/acs`
- Login page: `https://portal.litware.com/login`

Which value should you enter in the **Reply URL** field of the Basic SAML Configuration?

- A. `https://portal.litware.com/sp`
- B. `https://portal.litware.com/sso/acs`
- C. `https://portal.litware.com/login`
- D. The Login URL shown in the Set up Litware Portal section of the Microsoft Entra admin center

Q14 **Yes/No series** Configure and manage application-level and tenant-level settings

You manage an enterprise application named Payroll in the Contoso tenant. Several users are assigned to Payroll.

For each of the following statements, select Yes or No.

1. If you set **Visible to users** to No on Payroll, assigned users can no longer sign in to Payroll.
2. If you set **Enabled for users to sign in?** to No on Payroll, Microsoft Entra ID stops issuing tokens for Payroll, even to assigned users.
3. The **Users can register applications** setting is configured on the Properties page of each enterprise application.

Q15 **Drag/order** Design and implement integration for SaaS apps

The SAML signing certificate of a gallery SaaS app expires in 25 days. The app can trust more than one signing certificate at a time, but it doesn't pick up new certificates automatically. You must renew with no downtime.

Which **five** actions should you perform, **in sequence**?

- A. On the SAML Signing Certificate page, select New Certificate, choose an expiration date that overlaps the current certificate, and select Save.
- B. Download the new certificate from its row on the SAML Signing Certificate page.
- C. Upload the new certificate to the SaaS app's single sign-on settings.
- D. In the new certificate's row, select Make certificate active.
- E. Sign in to the app to confirm that SSO works.
- F. Delete the current active certificate.
- G. Edit the expiration date of the current active certificate.

Q16 **Multiple choice** Configure and manage user and admin consent

Contoso sets User consent for applications to **Allow user consent for apps from verified publishers, for selected permissions**. The admin consent workflow is off. A user tries to sign in to a third-party app from an **unverified** publisher that requests delegated Files.Read. The user sees a message that admin approval is needed, with no way to ask for it.

You need users to be able to send a request for review directly from the consent prompt. Security settings must not be weakened.

What should you do?

- A. Change User consent for applications to Allow user consent for apps.
- B. Turn on Users can request admin consent to apps they are unable to consent to, and select reviewers.
- C. Classify Files.Read as a low impact permission.
- D. Disable risk-based step-up consent.

Q17 **Yes/No series** Configure and manage user and admin consent

Contoso enables the admin consent workflow with these settings:

- Who can review admin consent requests: a group named AppReviewers
- Consent request expires after (days): 14

AppReviewers contains Ana, who holds no admin role, and Luis, who holds the Cloud Application Administrator role. A user creates request R1 for an app that requests the Microsoft Graph **delegated** permission Mail.Read. The next day, you add Pedro, a Cloud Application Administrator, to AppReviewers.

For each of the following statements, select Yes or No.

1. Ana can approve R1.
2. Luis can approve R1.
3. Pedro can act on R1.

Q18 **Select two** Assign appropriate Microsoft Entra roles to manage enterprise applications

A user is assigned **only** the Cloud Application Administrator role.

Which **two** tasks can the user perform? Each correct answer presents a complete solution.

- A. Configure SAML single sign-on for a gallery app.
- B. Create an Application Proxy connector group.
- C. Grant tenant-wide admin consent for an app that requests the Microsoft Graph delegated permission User.Read.All.
- D. Grant tenant-wide admin consent for an app that requests the Microsoft Graph application permission Mail.Read.
- E. Create a Conditional Access policy that targets the app.

Case study 1: Fabrikam

Fabrikam has a Microsoft Entra ID P1 license. The finance team uses three SaaS apps integrated with Microsoft Entra SSO: Expensely, Budgeto, and Ledgerly.

- Expensely has **Assignment required** set to Yes. The security group **Finance** is assigned to Expensely.
- Finance contains a nested security group named **Finance-Contractors**.
- Management wants Finance users to find the three finance apps together, on a separate tab in the My Apps portal.

Q19 Case study 1 (multiple choice)

Assign, classify, and manage users, groups, and app roles for enterprise applications

Refer to Case study 1. Users who are direct members of Finance can sign in to Expensely. Users who are members only of Finance-Contractors get an error that they aren't assigned to the app.

What should you do so Finance-Contractors members can sign in, while keeping access limited to finance users?

- A. Set Assignment required to No on Expensely.
- B. Assign the Finance-Contractors group directly to Expensely.
- C. Set Visible to users to Yes on Expensely.
- D. Add Finance-Contractors as an owner of Expensely.

Q20 Case study 1 (multiple choice) Create and manage application collections

Refer to Case study 1. You need to meet the management requirement for the My Apps portal.

What should you do?

- A. In Enterprise apps > App launchers, create a collection that contains Expensely, Budgeto, and Ledgerly, and assign it to Finance.
- B. Create an app role named Finance in each of the three apps.
- C. Create an administrative unit that contains the three apps.
- D. Upload the same custom logo to the three apps.

Subdominio 3: App registrations

Q21 Multiple choice Create app registrations

Contoso set **Users can register applications** to No. A developer named Dev1 must be able to create app registrations. You must follow the principle of least privilege.

What should you do?

- A. Assign Dev1 the Application Developer role.
- B. Assign Dev1 the Cloud Application Administrator role.
- C. Assign Dev1 the Application Administrator role.
- D. Set Users can register applications back to Yes.

Q22 Yes/No series Plan for app registrations

Contoso registers an app named HRPortal with the supported account type **Accounts in any organizational directory**. An administrator in the Fabrikam tenant grants tenant-wide admin consent to HRPortal.

For each of the following statements, select Yes or No.

1. An application object for HRPortal is created in the Fabrikam tenant.
2. A service principal for HRPortal is created in the Fabrikam tenant.
3. When a Contoso developer changes a property of HRPortal's application object, the change is reflected in HRPortal's service principal in the Contoso tenant.

Q23 Multiple choice Configure app authentication

A developer builds a React single-page app that signs in users with MSAL.js by using the authorization code flow with PKCE. The app runs entirely in the browser at `https://app.contoso.com`.

How should you configure the redirect URI in the app registration?

- A. Add a Web platform with the redirect URI `https://app.contoso.com`.
- B. Add a Single-page application platform with the redirect URI `https://app.contoso.com`.
- C. Add a Mobile and desktop applications platform and select a generated redirect URI.
- D. Don't add a redirect URI. Only confidential clients need one.

Q24 Multiple choice Configure app authentication

A GitHub Actions workflow deploys resources to Azure by using an app registration named Deployer. The security team forbids storing any secret or certificate in GitHub.

Which credential should you add to Deployer?

- A. A client secret with a 24-month expiration
- B. A certificate, with its private key stored as a GitHub encrypted secret
- C. A federated credential using the GitHub Actions deploying Azure resources scenario
- D. A system-assigned managed identity for the GitHub-hosted runner

Q25 Drag/order Configure API permissions

You register a web API named OrdersAPI and a client web app named OrdersWeb. OrdersWeb must call OrdersAPI **on behalf of the signed-in user** with a permission named Orders.Read. Users must not see a consent prompt.

Which **four** actions should you perform, **in sequence**?

- A. In OrdersAPI, open Expose an API and add the Application ID URI (`api://<client-id>`).
- B. In OrdersAPI, select Add a scope, name it Orders.Read, and set Who can consent to Admins and users.
- C. In OrdersWeb, open API permissions > Add a permission > My APIs, select OrdersAPI, and add the delegated permission Orders.Read.
- D. In OrdersWeb API permissions, select Grant admin consent for the tenant.
- E. In OrdersAPI, create an app role with Allowed member types set to Applications.
- F. Add the OrdersWeb redirect URI to the OrdersAPI app registration.

Q26 Multiple choice Create app roles

A developer wants the tokens of a survey app to include a claim that the code can check with the value **Survey.Create**. Administrators will grant it to users and security groups. Contoso has Microsoft Entra ID P1.

What should you do?

- A. In App registrations > Expose an API, add a scope named Survey.Create.
- B. In App registrations > App roles, create an app role with Allowed member types Users/Groups and Value Survey.Create, and then assign users and groups in Enterprise apps > Users and groups.
- C. In App registrations > Token configuration, add a groups claim.
- D. Create a custom Microsoft Entra directory role named Survey.Create.

Q27 Select two Configure API permissions

A background service (daemon) with no signed-in user must read the profiles of all users through Microsoft Graph.

Which **two** actions should you perform? Each correct answer presents part of the solution.

- A. Add the Microsoft Graph **application** permission User.Read.All.
- B. Add the Microsoft Graph **delegated** permission User.Read.All.
- C. Grant admin consent for the tenant.
- D. Add a redirect URI of type Web.
- E. Set Allow public client flows to Yes.

Q28 Multiple choice Create app roles

A SAML app authorizes users based on the groups claim, which is set to **All groups**. Some users are members of more than 300 groups. For those users, the token contains no group list, and access fails. The app only cares about four groups that are assigned to it.

What should you change in Token configuration?

- A. Set the groups claim to Groups assigned to the application.
- B. Keep All groups and increase the maximum token size.
- C. Add the Directory roles group type to the claim.
- D. Convert the four groups to distribution lists.

Q29 Yes/No series Create app roles

You define app roles in the app registration of an API named InventoryAPI.

For each of the following statements, select Yes or No.

1. An app role with Allowed member types set to Applications appears as an application permission when a client app selects InventoryAPI under API permissions > My APIs.
2. If you add a service principal to a security group and assign an app role to that group, the service principal's tokens include the roles claim.
3. When you disable an app role, the existing assignments stop sending that role in tokens immediately.

Q30 Multiple choice Configure API permissions

Your API exposes a custom scope named Reports.ReadAll with **Who can consent** set to **Admins only**. The tenant's user consent setting is **Allow user consent for apps**. A user signs in to a client app that requests Reports.ReadAll for the first time. No consent has been granted yet.

What happens?

- A. The user consents, because the tenant allows user consent for apps.
- B. The user consents, because custom application scopes never require admin consent.
- C. The user can't consent. An administrator must grant consent for the scope.
- D. The token is issued without the scope, and the app works with reduced permissions.

Subdominio 4: Defender for Cloud Apps

Q31 **Multiple choice** Analyze Cloud Discovery results

The security team exported 30 days of traffic logs from a Palo Alto firewall. They want a **one-time** assessment of which cloud apps employees use, without deploying anything on the network.

What should you do in Microsoft Defender for Cloud Apps?

- A. Create a snapshot report and upload the log files.
- B. Deploy a log collector and forward the firewall logs over Syslog.
- C. Turn on the Microsoft Defender for Endpoint integration.
- D. Connect the firewall by using an app connector.

Q32 **Select two** Analyze Cloud Discovery results

Contoso needs **continuous** Cloud Discovery reports. Some employees work only from home on corporate Windows laptops, and the office firewall can send logs over Syslog.

Which **two** methods produce continuous reports? Each correct answer presents a complete solution.

- A. Microsoft Defender for Endpoint integration
- B. A log collector that receives the firewall logs over Syslog or FTP
- C. A snapshot report uploaded every week
- D. The Microsoft 365 app connector
- E. A Conditional Access app control session policy

Q33 **Drag/order** Analyze Cloud Discovery results

Contoso's Windows devices are onboarded to Microsoft Defender for Endpoint. You need to block access to a discovered app named FileDropX on those devices by using the Defender for Cloud Apps integration.

Which **four** actions should you perform, **in sequence**?

- A. In Defender for Endpoint, make sure Cloud Protection and Network Protection are turned on for the devices.
- B. In Settings > Cloud Apps > Cloud Discovery > Microsoft Defender for Endpoint, select Enforce app access.
- C. In Settings > Endpoints > Advanced features, turn on Custom network indicators.
- D. In Cloud Discovery > Discovered apps, tag FileDropX as Unsanctioned.
- E. Create a session policy with the Block action for FileDropX.
- F. Upload a snapshot report of the firewall logs.

Q34 Yes/No series Analyze Cloud Discovery results

For each of the following statements, select Yes or No.

1. Fabrikam doesn't use Defender for Endpoint or any integrated Secure Web Gateway. When an admin tags an app as Unsanctioned, access to the app is blocked for all users.
2. With the Defender for Endpoint integration, it can take up to three hours from tagging an app as Unsanctioned until the app is blocked on devices.
3. With the Defender for Endpoint integration, you can block an unsanctioned app only for specific device groups by using a scoped profile.

Q35 Multiple choice Configure Conditional Access app control

Salesforce is integrated with Microsoft Entra ID for SAML SSO. In Defender for Cloud Apps, you create a session policy that blocks downloads from unmanaged devices for Salesforce. Users on unmanaged devices can still download files. No Conditional Access policy targets Salesforce.

What should you do?

- A. Connect Salesforce by using an app connector.
- B. Create a Conditional Access policy that targets Salesforce with the session control Use Conditional Access App Control set to Use custom policy.
- C. Create a Conditional Access policy that targets Salesforce with the session control Use app enforced restrictions.
- D. Tag Salesforce as Sanctioned in the cloud app catalog.

Q36 Multiple choice Create access and session policies in Defender for Cloud Apps

Contoso routes Dropbox sessions to Defender for Cloud Apps by using Conditional Access app control. Users must be able to use Dropbox in a browser, but the Dropbox **desktop sync client** must be blocked so it can't bypass the browser controls.

What should you create?

- A. A session policy with the action Block for Dropbox
- B. An access policy with the Client app filter set to Mobile and desktop and the action Block
- C. An OAuth app policy that revokes Dropbox
- D. An app discovery policy that tags Dropbox as Unsanctioned

Q37 Multiple choice Implement application-enforced restrictions

Contoso has Microsoft Entra ID P1 and **no** Defender for Cloud Apps licenses. On unmanaged devices, users must get limited, web-only access to SharePoint Online with no downloads. On compliant devices, they must get full access.

What should you configure?

- A. A Conditional Access policy for SharePoint Online with the session control Use app enforced restrictions, together with the SharePoint unmanaged devices setting Allow limited, web-only access
- B. A Conditional Access policy for SharePoint Online with the session control Use Conditional Access App Control
- C. A Conditional Access policy for SharePoint Online with the grant control Require device to be marked as compliant
- D. A Defender for Cloud Apps session policy that blocks downloads

Q38 Multiple choice Implement and manage policies for OAuth apps

Microsoft 365 is connected to Defender for Cloud Apps by using the app connector. You need to be alerted and automatically revoke any OAuth app that has a **high** permission level, **rare** community use, and was authorized by more than 50 users.

What should you create?

- A. An OAuth app policy with the filters Permission level equals High, Community use equals Rare, and Authorized by greater than 50 users, and the governance action Revoke app
- B. An app discovery policy with the governance action Tag app as unsanctioned
- C. A session policy that blocks the app for all users
- D. A built-in OAuth anomaly detection policy with custom filters

Case study 2: Litware

Litware has licenses for Microsoft Defender for Cloud Apps and Microsoft Defender for Endpoint. All Windows devices are onboarded to Defender for Endpoint, and Cloud Discovery is running.

- The compliance team says that, for Litware, certifications such as SOC 2 and ISO 27001 matter more than general facts about the vendor (founding year, popularity). Risk scores for **all** apps must reflect this.
- An internal note says the approved app Litware Notes shows a score of 5, but management wants it shown as 9.
- The security team needs visibility into user and admin activities in **ServiceNow** through the vendor's API, without routing users through a proxy.

Q39 Case study 2 (multiple choice) Manage the Cloud app catalog

Refer to Case study 2. You need to meet the compliance team requirement.

What should you do?

- A. In Settings > Cloud Apps > Cloud Discovery > Score metrics, increase the importance of the Compliance category and lower the General category.
- B. Use Override app score for each app in the catalog.
- C. Select Request score update on each app.
- D. Create a custom app for each vendor with the correct compliance data.

Q40 Case study 2 (multiple choice) Configure connected apps

Refer to Case study 2. You need to meet the security team requirement for ServiceNow.

What should you do?

- A. Connect ServiceNow by using an app connector in Settings > Cloud Apps > Connected apps > App Connectors.
- B. Onboard ServiceNow to Conditional Access app control and create a session policy.
- C. Rely on Cloud Discovery data from Defender for Endpoint.
- D. Create an OAuth app policy for ServiceNow.

5. Respuestas y explicaciones

Lee siempre el "por qué las otras no". El SC-300 se pierde en los distractores, no en la teoría.

Subdominio 1: Identities for applications and Azure workloads

Q1 Multiple choice

Respuesta: B

Por qué es correcta: La user-assigned managed identity es un recurso aparte con **ciclo de vida independiente** y se puede asignar a muchos recursos. Learn la pone justo para "workloads needing preauthorization to a secure resource" y "resources recycled frequently, but permissions should stay consistent". Sin credenciales que manejar.

Por qué las otras no:

- A: la system-assigned nace y muere con cada instancia, no se comparte y no existe antes del deploy, así que no puedes pre-autorizarla.
- C: funciona, pero obliga a manejar y rotar un secreto. La pregunta dice "must not manage any credentials".
- D: user accounts como service accounts no se recomiendan, y una cuenta sincronizada no se convierte en service principal.

Fuente: <https://learn.microsoft.com/entra/identity/managed-identities-azure-resources/overview#differences-between-system-assigned-and-user-assigned-managed-identities>

Q2 Yes/No series

Respuesta: 1 = Yes, 2 = No, 3 = No

Por qué es correcta:

- 1 Yes. La system-assigned comparte ciclo de vida con el recurso: cuando borras la VM, Azure borra su service principal.
- 2 No. La user-assigned tiene **ciclo de vida independiente** y hay que borrarla a mano. Además sigue asignada a App1.
- 3 No. La system-assigned **solo se asocia a un recurso**. Para compartir identidad usas una user-assigned.

Por qué las otras no:

- Trampa de la 1: pensar que queda un service principal huérfano. Learn dice que Azure lo borra por ti.
- Trampa de la 2: confundir "asignada a" con "pertenece a". UAMI1 vive sola en su resource group.
- Trampa de la 3: "system-assigned" suena a "del sistema, para todos". Es lo contrario: una identidad, un recurso.

Fuente: <https://learn.microsoft.com/entra/identity/managed-identities-azure-resources/overview#managed-identity-types>

Q3 Multiple choice

Respuesta: C

Por qué es correcta: Una managed identity solo existe en recursos de Azure. Un server fuera de Azure puede tener managed identity **solo si es Azure Arc-enabled**, y aquí Arc está prohibido. Queda un service principal, y Learn dice que el **certificate** es el tipo de credencial recomendado porque es más seguro que el client secret.

Por qué las otras no:

- A: sin Arc, un server on-premises no tiene system-assigned managed identity. Trampa clásica: "managed identity para todo".
- B: igual que A. La user-assigned se asigna a recursos de Azure, no a servers sueltos en tu datacenter.
- D: funciona, pero el client secret es justo el "password-like string" que el equipo de seguridad no quiere.

Fuente: <https://learn.microsoft.com/entra/identity-platform/how-to-add-credentials#add-a-credential-to-your-application> y <https://learn.microsoft.com/azure/azure-arc/servers/managed-identity-authentication>

Q4 Select two

Respuesta: B y C

Por qué es correcta: Learn lo repite en cada método (portal, CLI, PowerShell, REST): para asignar una user-assigned a una VM necesitas **Virtual Machine Contributor** y **Managed Identity Operator**, y "no other Microsoft Entra directory role assignments are required".

Por qué las otras no:

- A: Managed Identity Contributor es para **crear** (y borrar) user-assigned identities. Aquí la identidad ya existe; solo se asigna.
- D: es un rol de Microsoft Entra para apps. Asignar managed identities es Azure RBAC, no un rol de directorio.
- E: Owner alcanza, pero rompe least privilege.

Fuente: <https://learn.microsoft.com/entra/identity/managed-identities-azure-resources/how-to-configure-managed-identities#user-assigned-managed-identity>

Q5 Drag/order

Respuesta: A, B, C, D

Por qué es correcta: Es la secuencia de Learn: 1) crear la managed identity, 1.1) asignarla al recurso "source" (la web app), 2) **autorizarla en el recurso "target"** (rol de datos en el storage) y 3) usarla desde el código con Azure.Identity o MSAL. Si hay varias user-assigned en el recurso, conviene pasar el client ID para no depender del default.

Por qué las otras no:

- E: una managed identity no tiene application object ni aparece en App registrations. Y crear un secreto rompe el requisito de "no secrets".
- F: el acceso a Storage es Azure RBAC en el recurso. No hay admin consent de por medio.

Fuente: <https://learn.microsoft.com/entra/identity/managed-identities-azure-resources/overview#use-managed-identity-directly>

Q6 Multiple choice

Respuesta: B

Por qué es correcta: La **gMSA** es la identidad recomendada para servicios on-premises. Sirve para un server o para una **granja de servers o detrás de un load balancer**, y Windows cambia su password automáticamente (cada 30 días, 240 bytes aleatorios).

Por qué las otras no:

- A: la sMSA corre en **un solo server**. La tabla de Learn dice "App runs on multiple servers: No" y "App runs behind a load balancer: No".
- C: managed identity es para recursos de Azure. Aquí no hay Azure y el servicio necesita identidad de dominio.
- D: password manual que nunca cambia. Es lo que Learn pide usar solo si no hay MSA posible.

Fuente: <https://learn.microsoft.com/entra/architecture/service-accounts-on-premises#choose-the-right-type-of-service-account>

Q7 Multiple choice

Respuesta: B

Por qué es correcta: Una managed identity **solo tiene service principal, no tiene application object**.

Por eso Learn dice que los permisos de Microsoft Graph "need to be granted directly to the service principal", con una app role assignment (por ejemplo New-MgServicePrincipalAppRoleAssignment).

Para dar application permissions de Graph necesitas Privileged Role Administrator.

Por qué las otras no:

- A: la managed identity no aparece en App registrations. No hay pantalla de API permissions para ella.
- C: Azure RBAC da acceso a recursos de Azure, no a datos de Microsoft Graph. Confundir los dos planos es la trampa.
- D: la página Permissions de Enterprise applications muestra y revisa permisos; no es donde se agregan application permissions a una managed identity.

Fuente: <https://learn.microsoft.com/entra/identity/managed-identities-azure-resources/managed-identities-faq#do-managed-identities-have-a-backing-app-object> y

<https://learn.microsoft.com/entra/identity/managed-identities-azure-resources/how-to-assign-app-role-managed-identity>

Q8 Yes/No series

Respuesta: 1 = Yes, 2 = No, 3 = No

Por qué es correcta:

- 1 Yes. Registrar desde el portal crea **los dos objetos** en el home tenant. (Con Microsoft Graph API, crear el service principal es un paso aparte.)
- 2 No. El service principal de una managed identity "doesn't have an associated app object". Se le dan permisos, pero no se edita directo.
- 3 No. El service principal legacy no tiene app registration y "can only be used in the tenant where it was created".

Por qué las otras no:

- Trampa de la 1: creer que el service principal aparece solo cuando alguien consiente. Eso pasa en **otros** tenants (multitenant), no en el home tenant.
- Trampa de la 2: pensar que todo service principal tiene su app registration.
- Trampa de la 3: confundir legacy con multitenant.

Fuente: <https://learn.microsoft.com/entra/identity-platform/app-objects-and-service-principals#service-principal-object>

Subdominio 2: Enterprise applications

Q9 Multiple choice

Respuesta: B

Por qué es correcta: **Application Administrator** administra todo en enterprise apps y app registrations **más los settings de Application Proxy**. Learn lo pone como least privileged para configurar apps de App Proxy y crear o borrar connector groups.

Por qué las otras no:

- A: Cloud Application Administrator tiene lo mismo que Application Administrator **excepto Application Proxy**. Esa es toda la diferencia, y el examen la busca.
- C: Application Developer solo registra apps (y consiente por sí mismo). No toca App Proxy ni SSO de apps ajenas.
- D: puede todo, pero rompe least privilege.

Fuente: <https://learn.microsoft.com/entra/identity/role-based-access-control/delegate-app-roles#assign-built-in-application-administrator-roles> y <https://learn.microsoft.com/entra/identity/role-based-access-control/delegate-by-task#application-proxy-least-privileged-roles>

Q10 Yes/No series

Respuesta: 1 = No, 2 = No, 3 = Yes

Por qué es correcta:

- 1 No. Con **Passthrough** no hay autenticación en Microsoft Entra, así que **Conditional Access no se aplica**. Para CA, MFA y SSO necesitas pre-auth **Microsoft Entra ID**.
- 2 No. Los connectors **solo abren conexiones de salida** (80 y 443) hacia el servicio. No hay inbound ni DMZ.
- 3 Yes. Learn pide **al menos dos connectors por connector group** (tres es lo óptimo).

Por qué las otras no:

- Trampa de la 1: pensar que CA "cubre todo lo que está en Enterprise apps". Si Entra no autentica, CA no evalúa.
- Trampa de la 2: pensar en App Proxy como un reverse proxy clásico con puerto abierto. Todo es outbound.
- Trampa de la 3: con un solo connector funciona, pero es un single point of failure.

Fuente: <https://learn.microsoft.com/entra/identity/app-proxy/application-proxy-faq#passthrough-preauthentication> y <https://learn.microsoft.com/entra/identity/app-proxy/conceptual-deployment-plan#plan-your-implementation>

Q11 Drag/order

Respuesta: A, B, C, D

Por qué es correcta: SSO a una app IWA con App Proxy es **Kerberos Constrained Delegation (KCD)**. Primero existe el connector (necesitas su computer account), luego configuras la delegación en AD al SPN de la app (prerrequisito en Learn), después publicas con pre-auth Microsoft Entra ID y al final eliges SSO **Integrated Windows authentication** con el SPN. Si connector y app estuvieran en dominios distintos, se usaría resource-based KCD (PrincipalsAllowedToDelegateToAccount).

Por qué las otras no:

- E: sin pre-auth de Entra **no hay opciones de SSO**. Learn: "Without preauthentication, SSO options are unavailable."
- F: la app habla Kerberos, no SAML. El SPN no es un Entity ID.

Fuente: <https://learn.microsoft.com/entra/identity/app-proxy/how-to-configure-sso-with-kcd#configure-single-sign-on>, <https://learn.microsoft.com/entra/identity/app-proxy/how-to-configure-sso-with-kcd#prerequisites> y <https://learn.microsoft.com/entra/identity/app-proxy/conceptual-deployment-plan#implement-your-solution>

Q12 Multiple choice

Respuesta: A

Por qué es correcta: Para custom domains, Learn pide un certificado **PFX con la private key** (y la cadena intermedia), subido en la página Application proxy de la app, y un registro **CNAME** que apunte el external URL al dominio `msappproxy.net`. El certificado se sube una vez por dominio y se reusa en apps nuevas.

Por qué las otras no:

- B: un .cer no trae private key, y Learn dice que no apuntes a IPs ni a nombres de servers porque no son estáticos.
- C: el TXT es para **verificar el dominio**, paso que ya está hecho. Con custom domain el certificado lo pones tú.
- D: el connector no recibe tráfico de internet. Todo es outbound.

Fuente: <https://learn.microsoft.com/entra/identity/app-proxy/how-to-configure-custom-domain#certificates-for-custom-domains> y <https://learn.microsoft.com/entra/identity/app-proxy/how-to-configure-custom-domain#set-up-and-use-custom-domains>

Q13 Multiple choice

Respuesta: B

Por qué es correcta: En Entra el campo se llama **Reply URL (Assertion Consumer Service URL)**: es a donde Entra manda la respuesta SAML. El **Identifier (Entity ID)** y el Reply URL son los obligatorios.

Por qué las otras no:

- A: es el **Identifier (Entity ID)**. Va en otro campo.
- C: es el **Sign on URL**, que solo se usa para SP-initiated SSO.
- D: el Login URL y el Microsoft Entra Identifier de la sección "Set up" son valores de Entra que **tú le das al vendor**, no al revés.

Fuente: <https://learn.microsoft.com/entra/identity/enterprise-apps/add-application-portal-setup-sso#configure-single-sign-on-in-the-tenant>

Q14 Yes/No series

Respuesta: 1 = No, 2 = Yes, 3 = No

Por qué es correcta:

- 1 No. Visible to users solo esconde la app en My Apps y en el launcher de Microsoft 365. El acceso sigue igual.
- 2 Yes. Con Enabled = No "no users are able to sign in... Tokens aren't issued", y también limita a service principals que usan application permissions.
- 3 No. Es un setting **de tenant**: Entra ID > Users > User settings. No vive en cada app.

Por qué las otras no:

- Trampa de la 1: confundir "no la veo" con "no puedo entrar".
- Trampa de la 2: pensar que Enabled = No es lo mismo que quitar asignaciones. Enabled apaga todo, asignados incluidos, sin perder la configuración.
- Trampa de la 3: mezclar settings de app con settings de tenant, que es justo lo que pide el outline.

Fuente: <https://learn.microsoft.com/entra/identity/enterprise-apps/application-properties#enabled-for-users-to-sign-in> y <https://learn.microsoft.com/entra/identity/role-based-access-control/delegate-app-roles#restrict-who-can-create-applications>

Q15 Drag/order

Respuesta: A, B, C, D, E

Por qué es correcta: Es el flujo de Learn para renovar sin downtime: crear el certificado nuevo con fecha que se traslape (queda **Inactive**), descargarlo, subirlo a la app, **activarlo** en Entra y probar. Datos para memorizar: el certificado autogenerado dura **3 años**, y Entra avisa a los **60, 30 y 7 días** hasta a 5 correos.

Por qué las otras no:

- F: borrar el activo antes de tener el nuevo en la app corta el SSO.
- G: la fecha de un certificado guardado **no se puede cambiar**. Learn: hay que crear uno nuevo.

Fuente: <https://learn.microsoft.com/entra/identity/enterprise-apps/tutorial-manage-certificates-for-federated-single-sign-on#renew-a-certificate-that-is-set-to-expire-soon>

Q16 Multiple choice

Respuesta: B

Por qué es correcta: El **admin consent workflow** deja que el usuario pida aprobación desde el prompt cuando no puede consentir. La solicitud llega por correo a los reviewers. No cambia lo que el usuario puede consentir, así que no baja la seguridad.

Por qué las otras no:

- A: quita la protección de verified publishers y permisos low impact. Justo lo que se pidió no hacer.
- C: aunque Files.Read fuera low impact, el publisher sigue sin estar verificado, así que el usuario tampoco podría consentir.
- D: step-up consent no es la causa aquí (el bloqueo viene del setting de verified publisher), y apagarlo **reduce** la seguridad.

Fuente: <https://learn.microsoft.com/entra/identity/enterprise-apps/configure-admin-consent-workflow#enable-the-admin-consent-workflow> y <https://learn.microsoft.com/entra/identity/enterprise-apps/configure-user-consent#configure-user-consent-settings>

Q17 Yes/No series

Respuesta: 1 = No, 2 = Yes, 3 = No

Por qué es correcta:

- 1 No. Ser reviewer **no eleva privilegios**. Para aprobar necesitas los permisos para dar admin consent. Ana puede ver, bloquear o negar, pero no aprobar.
- 2 Yes. Cloud Application Administrator puede dar consent a cualquier permiso **excepto application permissions (app roles) de Microsoft Graph**. Mail.Read aquí es delegated.
- 3 No. Learn: los reviewers nuevos "aren't able to act on existing or expired admin consent requests".

Por qué las otras no:

- Trampa de la 1: pensar que la lista de reviewers da permisos.
- Trampa de la 2: creer que ningún rol de apps puede consentir permisos de Graph. Solo están excluidas las **application permissions** de Graph.
- Trampa de la 3: asumir que los reviewers nuevos heredan la cola de solicitudes.

Fuente: <https://learn.microsoft.com/entra/identity/enterprise-apps/configure-admin-consent-workflow#enable-the-admin-consent-workflow> y <https://learn.microsoft.com/entra/identity/enterprise-apps/grant-admin-consent#prerequisites>

Q18 Select two

Respuesta: A y C

Por qué es correcta: Cloud Application Administrator maneja todos los aspectos de enterprise apps y app registrations (SSO incluido) y puede dar consent a permisos **delegated** y a application permissions que **no sean de Microsoft Graph**.

Por qué las otras no:

- B: Application Proxy es lo único que Cloud Application Administrator no tiene. Para connector groups necesitas Application Administrator.
- D: application permissions de Microsoft Graph piden un rol más alto, como **Privileged Role Administrator**.
- E: ni Application Administrator ni Cloud Application Administrator administran Conditional Access.

Fuente: <https://learn.microsoft.com/entra/identity/role-based-access-control/permissions-reference#cloud-application-administrator>

Q19 Case study 1 (multiple choice)

Respuesta: B

Por qué es correcta: En la asignación a apps, **la membresía anidada no se soporta**: "The assignment doesn't cascade to nested groups." Hay que asignar Finance-Contractors directo. Asignar grupos pide P1 o P2, y Fabrikam lo tiene.

Por qué las otras no:

- A: con Assignment required = No entra **todo el tenant**. Se rompe el "limited to finance users".
- C: la visibilidad solo afecta si se ve en My Apps. No da acceso.
- D: los owners administran la app, no reciben acceso por eso.

Fuente: <https://learn.microsoft.com/entra/identity/enterprise-apps/assign-user-or-group-access-portal#prerequisites>

Q20 Case study 1 (multiple choice)

Respuesta: A

Por qué es correcta: Una **collection** agrupa apps relacionadas en su propia pestaña de My Apps. Se crea en Enterprise apps > App launchers, pide **P1 o P2** y se asigna a usuarios o grupos. Ojo: la collection solo filtra apps que el usuario ya tiene; si no está asignado a la app, no la ve.

Por qué las otras no:

- B: app roles definen autorización dentro de la app (claim roles), no cómo se agrupan en My Apps.
- C: administrative units delegan administración de usuarios, grupos y devices. No organizan My Apps.
- D: el logo es cosmético. No crea pestañas.

Fuente: <https://learn.microsoft.com/entra/identity/enterprise-apps/access-panel-collections#create-a-collection>

Subdominio 3: App registrations

Q21 Multiple choice

Respuesta: A

Por qué es correcta: Learn dice que cuando el switch global está en No, le devuelves la capacidad a personas específicas con el rol **Application Developer**. Además queda como owner de las apps que crea.

Por qué las otras no:

- B: puede registrar apps, pero también administra todas las apps del tenant. Más privilegio del necesario.
- C: igual que B, y encima Application Proxy.
- D: abre el registro para **todos** los usuarios, no solo para Dev1.

Fuente: <https://learn.microsoft.com/entra/identity/role-based-access-control/delegate-app-roles#restrict-who-can-create-applications>

Q22 Yes/No series

Respuesta: 1 = No, 2 = Yes, 3 = Yes

Por qué es correcta:

- 1 No. El application object es **uno solo** y vive en el home tenant (Contoso). Es la plantilla.
- 2 Yes. Cuando Fabrikam consiente, se crea un **service principal** en Fabrikam: la instancia local de la app.
- 3 Yes. Los cambios al application object se reflejan en el service principal **del home tenant**.

Por qué las otras no:

- Trampa de la 1: pensar que cada tenant tiene su "copia" de la app registration. Fabrikam solo ve una enterprise app.
- Trampa de la 2: creer que el SP se crea solo en el tenant que registró.
- Trampa de la 3: la afirmación es solo sobre el home tenant; ahí sí aplica.

Fuente: <https://learn.microsoft.com/entra/identity-platform/app-objects-and-service-principals#relationship-between-application-objects-and-service-principals> y <https://learn.microsoft.com/entra/identity-platform/app-objects-and-service-principals#consequences-of-modifying-and-deleting-applications>

Q23 Multiple choice

Respuesta: B

Por qué es correcta: En Authentication, cada redirect URI va con su **plataforma**. Para apps del lado del cliente (JavaScript, Angular, React, Blazor WebAssembly) la plataforma es **Single-page application**.

Por qué las otras no:

- A: Web es para apps que corren en un servidor. Una SPA con PKCE registrada como Web es un error típico.
- C: Mobile and desktop es para apps nativas, con URIs generados.
- D: al revés. Quien no necesita redirect URI es el **daemon**; una app que inicia sesión de usuarios siempre lo necesita.

Fuente: <https://learn.microsoft.com/entra/identity-platform/how-to-add-redirect-uri#add-a-redirect-uri> y <https://learn.microsoft.com/entra/identity-platform/msal-client-application-configuration#redirect-uri>

Q24 Multiple choice

Respuesta: C

Por qué es correcta: La **federated credential** (workload identity federation) deja que GitHub Actions cambie su token por uno de Microsoft Entra **sin guardar secretos**. Learn tiene el escenario "GitHub actions deploying Azure resources" en Certificates & secrets > Federated credentials.

Por qué las otras no:

- A: es un secreto, y además 24 meses es el máximo permitido (Learn recomienda menos de 12).
- B: el certificado es mejor que el secret, pero guardar su private key en GitHub rompe la regla.
- D: un runner hospedado por GitHub no es un recurso de Azure, así que no tiene managed identity.

Fuente: <https://learn.microsoft.com/entra/identity-platform/how-to-add-credentials#add-a-credential-to-your-application>

Q25 Drag/order

Respuesta: A, B, C, D

Por qué es correcta: "On behalf of the signed-in user" = permiso **delegated** = **scope**. El App ID URI es el prefijo de los scopes y va primero; después creas el scope, el cliente lo pide en My APIs, y el admin consent para el tenant evita el prompt a cada usuario.

Por qué las otras no:

- E: un app role con Applications crea una **application permission** (sin usuario). No es lo que pide el escenario.
- F: el redirect URI es del cliente y se configura en el cliente, no en la API.

Fuente: <https://learn.microsoft.com/entra/identity-platform/quickstart-configure-app-expose-web-apis#add-a-scope> y <https://learn.microsoft.com/entra/identity/enterprise-apps/grant-admin-consent#grant-admin-consent-in-app-registrations-pane>

Q26 Multiple choice

Respuesta: B

Por qué es correcta: Un **app role** con Allowed member types **Users/Groups** sale en el claim **roles** con el Value que definiste. Luego lo asignas en Enterprise apps. Asignar grupos a roles pide P1 o superior, y Contoso lo tiene.

Por qué las otras no:

- A: un scope es un permiso **delegated** que el cliente pide a la API. Sale en el claim scp, no representa el rol del usuario.
- C: el groups claim manda object IDs de grupos; el código tendría que mapear IDs a permisos. Learn recomienda app roles para evitarlo.
- D: los roles de directorio administran Microsoft Entra, no la lógica de tu app.

Fuente: <https://learn.microsoft.com/entra/identity-platform/howto-add-app-roles-in-apps#declare-roles-for-an-application>

Q27 Select two

Respuesta: A y C

Por qué es correcta: Sin usuario = **application permission** (app role). Las application permissions **solo las consiente un admin**, así que falta el admin consent.

Por qué las otras no:

- B: delegated necesita un usuario con sesión. El daemon no lo tiene.
- D: un daemon no necesita redirect URI.
- E: public client es para apps que no pueden guardar credenciales. Un daemon es confidential client.

Fuente: <https://learn.microsoft.com/entra/identity-platform/permissions-consent-overview#types-of-permissions>

Q28 Multiple choice

Respuesta: A

Por qué es correcta: El límite de grupos en el token es **150 para SAML** y **200 para JWT**. Si se pasa, Entra no manda el claim (overage). Learn recomienda **Groups assigned to the application** para organizaciones grandes: solo viajan los grupos asignados a la app.

Por qué las otras no:

- B: el tamaño del token no se configura. Ese límite existe a propósito.
- C: agrega más valores al claim, lo empeora.
- D: no reduce la cantidad de grupos del usuario y rompe la seguridad de la asignación.

Fuente: <https://learn.microsoft.com/entra/identity-platform/optional-claims#configure-groups-optional-claims>

Q29 Yes/No series

Respuesta: 1 = Yes, 2 = No, 3 = No

Por qué es correcta:

- 1 Yes. Learn: con Applications, el app role aparece como application permission en My APIs.
- 2 No. Learn: si metes un service principal en un grupo y le das el rol al grupo, Entra **no agrega el claim roles** a sus tokens.
- 3 No. Al deshabilitar, el rol ya no se puede asignar, pero **las asignaciones que existen se quedan y el rol sigue saliendo en los tokens**. Hay que quitar la asignación.

Por qué las otras no:

- Trampa de la 1: pensar que app role y application permission son cosas distintas. Son lo mismo visto desde dos lados.
- Trampa de la 2: asumir que la asignación por grupo funciona igual para usuarios y para service principals.
- Trampa de la 3: "disabled" suena a "desaparece", pero no borra asignaciones.

Fuente: <https://learn.microsoft.com/entra/identity-platform/howto-add-app-roles-in-apps#declare-roles-for-an-application>

Q30 Multiple choice

Respuesta: C

Por qué es correcta: "Who can consent: Admins only" hace que el scope **requiera admin consent**. Learn lo recomienda para permisos de alto privilegio. El user consent setting del tenant no puede abrir algo que la API marcó como solo admin.

Por qué las otras no:

- A: el setting de tenant decide si el usuario puede consentir **lo que es consentible por usuarios**. Un scope Admins only no lo es.
- B: Learn dice que los scopes custom, por default, no se consideran high-privilege. Pero aquí el owner de la API los marcó como Admins only. La trampa es aplicar la regla general a un caso configurado.
- D: la app no sigue "con menos permisos" sin avisar. Learn: cuando un permiso delegated requiere admin consent, el usuario ve un error de "unauthorized to consent" y tiene que pedirle acceso a un admin.

Fuente: <https://learn.microsoft.com/entra/identity-platform/quickstart-configure-app-expose-web-apis#add-a-scope> y <https://learn.microsoft.com/entra/identity-platform/consent-types-developer#requesting-consent-for-an-entire-tenant-through-admin-consent>

Subdominio 4: Defender for Cloud Apps

Q31 Multiple choice

Respuesta: A

Por qué es correcta: El **snapshot report** da visibilidad "ad-hoc" sobre logs que **subes a mano** desde firewalls y proxies. Palo Alto está en la lista de fuentes soportadas.

Por qué las otras no:

- B: el log collector es para reportes **continuos** y hay que desplegarlo en la red.
- C: la integración con Defender for Endpoint también es continua y mira endpoints, no los logs que ya exportaste.
- D: los app connectors se conectan por API a apps SaaS (Microsoft 365, ServiceNow...), no a firewalls.

Fuente: <https://learn.microsoft.com/defender-cloud-apps/set-up-cloud-discovery#snapshot-and-continuous-risk-assessment-reports>

Q32 Select two

Respuesta: A y B

Por qué es correcta: Learn lista para **continuous reports**: integración con **Defender for Endpoint** (extiende discovery fuera de la red corporativa, perfecto para home office), **log collector** (Syslog o FTP), integraciones con Secure Web Gateways y la API de discovery.

Por qué las otras no:

- C: subir snapshots cada semana sigue siendo snapshot. Manual, no continuo.
- D: el app connector da visibilidad dentro de Microsoft 365 por API. No descubre shadow IT del tráfico.
- E: session policies controlan sesiones de apps ya conectadas por CA. No son discovery.

Fuente: <https://learn.microsoft.com/defender-cloud-apps/set-up-cloud-discovery#snapshot-and-continuous-risk-assessment-reports>

Q33 Drag/order

Respuesta: A, B, C, D

Por qué es correcta: Learn pone como prerequisites **Cloud Protection y Network Protection** en Defender for Endpoint (y el add-on Microsoft Defender Browser Protection en navegadores que no son de Microsoft). Luego activas **Enforce app access** (tarda hasta 30 minutos), habilitas **Custom network indicators** y al final marcas la app como **Unsanctioned**, que sincroniza los dominios al endpoint.

Por qué las otras no:

- E: una session policy controla sesiones de apps que pasan por CA app control. No bloquea a nivel de red una app descubierta.
- F: el snapshot sirve para descubrir, no para bloquear.

Fuente: <https://learn.microsoft.com/defender-cloud-apps/mde-govern#enable-cloud-app-blocking-with-defender-for-endpoint> y <https://learn.microsoft.com/defender-cloud-apps/governance-discovery>

Q34 Yes/No series

Respuesta: 1 = No, 2 = Yes, 3 = Yes

Por qué es correcta:

- 1 No. "Unsanctioning an app doesn't block use." Sin integración, puedes **generar un block script** para tu appliance o exportar los dominios.
- 2 Yes. Hasta una hora de sync con Defender for Endpoint más hasta dos horas para empujar la política: **hasta tres horas**.
- 3 Yes. Con **scoped profiles** (Include o Exclude) eliges los device groups de Defender for Endpoint.

Por qué las otras no:

- Trampa de la 1: creer que la etiqueta bloquea sola. La etiqueta marca; el bloqueo lo hace otro componente.
- Trampa de la 2: esperar bloqueo instantáneo.
- Trampa de la 3: pensar que el bloqueo es todo o nada. Con MDE se puede acotar; con Zscaler, iboss y otros SWG no.

Fuente: <https://learn.microsoft.com/defender-cloud-apps/governance-discovery#sanctioningunsanctioning-an-app> y <https://learn.microsoft.com/defender-cloud-apps/mde-govern#block-apps-for-specific-device-groups>

Q35 Multiple choice

Respuesta: B

Por qué es correcta: Access y session policies necesitan que **una política de Conditional Access mande la sesión a Defender for Cloud Apps: Session > Use Conditional Access App Control**. Con **Use custom policy** se aplican las políticas avanzadas que creaste en Defender for Cloud Apps.

Por qué las otras no:

- A: el app connector trabaja por API (actividad, archivos, cuentas). No controla la sesión del navegador en tiempo real.
- C: app enforced restrictions solo funciona con **Exchange Online y SharePoint Online**.
- D: sanctioned es una etiqueta de discovery. No enruta sesiones.

Fuente: <https://learn.microsoft.com/defender-cloud-apps/session-policy-aad#prerequisites> y <https://learn.microsoft.com/defender-cloud-apps/troubleshooting-proxy#issues-when-onboarding-an-app>

Q36 Multiple choice

Respuesta: B

Por qué es correcta: Las **access policies** sirven para browser, mobile y desktop. Learn: bloquea los clientes nativos con una access policy y el filtro **Client app = Mobile and desktop**. Sin ese filtro, la access policy solo aplica a sesiones de browser.

Por qué las otras no:

- A: las session policies trabajan **en el browser**. No ven al cliente de escritorio.
- C: las OAuth app policies revisan permisos que usuarios dieron a apps OAuth. No bloquean un cliente de sync.
- D: Unsanctioned bloquearía Dropbox completo, incluido el browser, y el requisito dice que el browser sigue.

Fuente: <https://learn.microsoft.com/defender-cloud-apps/session-policy-aad#access-controls-in-session-policies> y <https://learn.microsoft.com/defender-cloud-apps/access-policy-aad#create-a-defender-for-cloud-apps-access-policy>

Q37 Multiple choice

Respuesta: A

Por qué es correcta: Use **app enforced restrictions** hace que Entra le pase a la app la info del device, y la app decide: experiencia **limitada** si no está administrado, **completa** si es compliant. Solo funciona con Exchange Online y SharePoint Online, y no necesita Defender for Cloud Apps. El setting de SharePoint "Allow limited, web-only access" crea esa política.

Por qué las otras no:

- B: CA App Control es Defender for Cloud Apps, y Contoso no tiene esas licencias.
- C: Require compliant **bloquea** a los no administrados. El requisito pide acceso limitado, no bloqueo.
- D: igual que B, requiere Defender for Cloud Apps.

Fuente: <https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-session#application-enforced-restrictions> y <https://learn.microsoft.com/sharepoint/control-access-from-unmanaged-devices#how-do-i-limit-access>

Q38 Multiple choice

Respuesta: A

Por qué es correcta: Las **OAuth app policies** filtran por **Permission level** (High, Medium, Low), **Community use** (Common, Uncommon, Rare) y cuántos usuarios autorizaron la app. Para Microsoft 365 la acción es **Revoke app**. Si tu tenant tiene app governance activo, la política se crea desde App governance.

Por qué las otras no:

- B: las app discovery policies trabajan sobre apps descubiertas en el tráfico, no sobre consentimientos OAuth en Microsoft 365.
- C: una session policy no revoca permisos que el usuario ya dio.
- D: las anomaly detection policies son out of the box: no les pones filtros y su severidad no se cambia.

Fuente: <https://learn.microsoft.com/defender-cloud-apps/app-permission-policy#create-a-new-oauth-app-policy> y <https://learn.microsoft.com/defender-cloud-apps/policies-cloud-discovery#detect-risky-oauth-apps>

Q39 Case study 2 (multiple choice)

Respuesta: A

Por qué es correcta: El score de cada app es un promedio ponderado de 4 categorías: General, Security, Compliance y Legal. En **Score metrics** cambias la **importancia** (Ignored a Very High) de campos o categorías, y eso aplica al cálculo de **todas** las apps del tenant.

Por qué las otras no:

- B: Override cambia el score de **una app** sin tocar los pesos. Sirve para Litware Notes, no para "all apps".
- C: Request score update le pide al equipo de Microsoft revisar datos de una app. No cambia tus pesos.
- D: custom apps son para apps que no están en el catálogo.

Fuente: <https://learn.microsoft.com/defender-cloud-apps/risk-score#customize-the-risk-score>

Q40 Case study 2 (multiple choice)

Respuesta: A

Por qué es correcta: Los **app connectors** usan la **API del proveedor** para dar visibilidad de cuentas, audit trail (actividad de usuarios y admins), governance de cuentas y datos. No pasan por proxy. ServiceNow tiene connector (recomendado con OAuth app tokens).

Por qué las otras no:

- B: CA app control es **reverse proxy** en tiempo real. El requisito dice "without routing users through a proxy".
- C: Cloud Discovery ve **tráfico** (qué apps se usan y cuánto), no las actividades dentro de ServiceNow.
- D: las OAuth app policies aplican a Microsoft 365, Google Workspace y Salesforce, y miran permisos de apps OAuth, no actividad de usuarios.

Fuente: <https://learn.microsoft.com/defender-cloud-apps/enable-instant-visibility-protection-and-governance-actions-for-your-apps#how-app-connectors-scan-and-collect-data>

6. Plan de la semana y ritual post-examen

Checklist antes de la sesión 4 (Identity governance, 20 a 25% del examen)

- ☐ Leí el mapa y las 12 trampas de M3.
- ☐ Contesté las 40 preguntas de M3 sin ver respuestas y revisé el "por qué las otras no".
- ☐ Anoté las preguntas que fallé para el Kahoot.
- ☐ Hice una vez el practice assessment oficial de Learn, sin estudiar antes.
- ☐ Recibí la guía de M4 y empecé su banco de 40 preguntas.

Si presentas el examen esta semana: llena el debrief el mismo día. Temas sí, preguntas no. Así el cohort acumula señal legítima y nadie arriesga su certificación.

Campo	Qué anotar
Resultado	Pass o no pass y el score por dominio que trae el reporte
Dominios que pesaron	Por sensación: cuál dominó y cuál casi no salió
Escenarios que costaron	Por tema, por ejemplo "AU vs restricted AU", "cross-tenant sync con error de consent"
Labs que salieron	Por tarea, por ejemplo "crear un AU y asignar un rol con scope", nunca pasos exactos
Qué hubiera estudiado más	Libre, en dos líneas

Objetivo de la sesión en vivo, para que sepas qué esperar.

El presenter no tiene que recitar menús ni números. Tiene que entender que casi todas las preguntas de M3 se resuelven con cuatro preguntas: **¿quién es la identidad?** (application object o service principal, system o user-assigned, y si vive dentro o fuera de Azure), **¿quién actúa y quién aprueba?** (delegated o application, qué rol puede consentir y qué hace el workflow cuando el usuario no puede), **¿por dónde entra el usuario a la app?** (SAML directo, App Proxy con pre-auth y KCD, y qué settings de la app filtran, esconden o apagan) y **¿qué ve y qué controla Defender for Cloud Apps?** (discovery por tráfico, connectors por API, proxy por Conditional Access). Si el presenter puede tomar cualquier pregunta del banco, señalar las dos o tres palabras que la delatan y explicar con sus palabras por qué cada distractor falla, la sesión cumplió. Los datos finos (3 años del certificado, 200 y 150 grupos, 24 meses del secret, 3 horas del bloqueo con MDE) se quedan en la guía para consulta.